NorthPeak
Growth
Marketing

CYBERSECURITY GOVERNANCE & POLICY FRAMEWORK

Version 1.0
March 2026
Confidential

TABLE OF CONTENT

1. EXECUTIVE SUMMARY 2
2. INTRODUCTION 3
   A. SCOPE 3
   B. OBJECTIVES 3
3. GOVERNANCE FRAMEWORK 4
   A. GOVERNANCE COMPONENTS 4
   B. ROLES AND RESPONSIBILITIES 4
   C. STRATEGIC ALIGNMENT 4
4. POLICY FRAMEWORK STRUCTURE 5
   A. FRAMEWORK STRUCTURE 5
   B. COMPONENT DEFINITIONS 5
   C. APPLICATION 5
5. POLICY GOVERNANCE MODEL 6
   A. POLICY LIFECYCLE 6
   B. REVIEW CYCLE 6
   C. ACCOUNTABILITY 6
6. POLICY SUITE 7
   A. INFORMATION SECURITY POLICY 7
   B. ACCESS CONTROL POLICY 8
   C. ACCEPTABLE USE POLICY 9
   D. DATA CLASSIFICATION AND HANDLING POLICY 10
   E. INCIDENT RESPONSE POLICY 11
7. CONTROL AREAS MAPPING 12
   A. CONTROL DOMAINS 12
   B. POLICY-TO-CONTROL MAPPING 12
   C. CONTROL COVERAGE SUMMARY 13
   D. FRAMEWORK ALIGNMENT 13
   E. KEY INSIGHT 13
8. RISK ALIGNMENT 14
   A. KEY RISK AREAS 14
   B. RISK-TO-CONTROL MAPPING 14
   C. RISK REDUCTION STRATEGY 14
   D. PRIORITY FOCUS AREAS 15
   E. KEY INSIGHT 15
9. CONTINUOUS IMPROVEMENT 15
   A. CONTINUOUS IMPROVEMENT ACTIVITIES 16
   B. METRICS AND MONITORING 16
   C. REVIEW CYCLE 16
   D. KEY INSIGHT 16
10. APPENDIX 16
   A. DEFINITIONS 17
   B. ACRONYMS 17
   C. POLICY SUMMARY 17
   D. DOCUMENT INFORMATION 17

EXECUTIVE SUMMARY

This document establishes the cybersecurity governance and policy framework for NorthPeak Growth Marketing. It defines how security is managed, enforced, and continuously improved across the organization.

The framework outlines the governance structure, policy requirements, and control expectations needed to protect company systems, client data, and business operations. It addresses key risks identified within the organization, particularly in identity management, credential security, and data protection.

By implementing this framework, NorthPeak Growth Marketing can establish consistent security practices, reduce exposure to common threats, and align security with business objectives while maintaining operational efficiency.

INTRODUCTION

NorthPeak Growth Marketing is a SaaS-driven marketing agency that relies on cloud platforms, third-party services, and distributed access to deliver services to clients. This operating model supports flexibility and scalability, but it also introduces security risks related to identity, access control, data handling, and third-party dependencies.

To manage these risks effectively, a structured governance and policy framework is required. This framework provides the foundation for defining security expectations, implementing controls, and ensuring accountability across the organization.

SCOPE

This framework applies to:

- All employees, contractors, and third parties
- All systems, applications, and devices used by the organization
- All company and client data

OBJECTIVES

- Establish a structured approach to managing cybersecurity risk.
- Define clear roles, responsibilities, and expectations.
- Ensure consistent implementation of security controls.
- Protect sensitive data and critical systems.
- Support business operations and client trust.

GOVERNANCE FRAMEWORK

OVERVIEW

The cybersecurity governance framework defines how security decisions are made, implemented, and monitored within the organization. It ensures that security aligns with business priorities and that risks are managed consistently and with accountability.

GOVERNANCE COMPONENTS

The framework is based on four key components:

Risk Management

- Identification, assessment, and prioritization of security risks
- Use of likelihood and impact to guide decision-making

Policy and Control Framework

- Establishment of policies and controls to manage risk
- Standardization of security requirements across systems

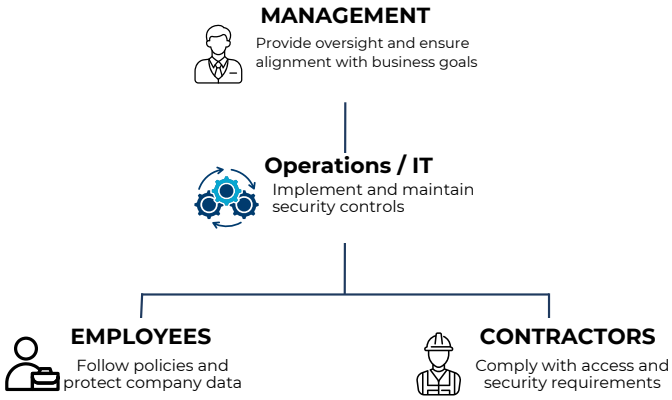
Compliance and Oversight

- Monitoring adherence to policies and controls
- Periodic reviews and audits of access, systems, and processes

DATA PROTECTION AND THIRD-PARTY RISK

- Protection of sensitive data based on classification
- Management of risks associated with vendors and external partners

ROLES AND RESPONSIBILITIES



STRATEGIC ALIGNMENT

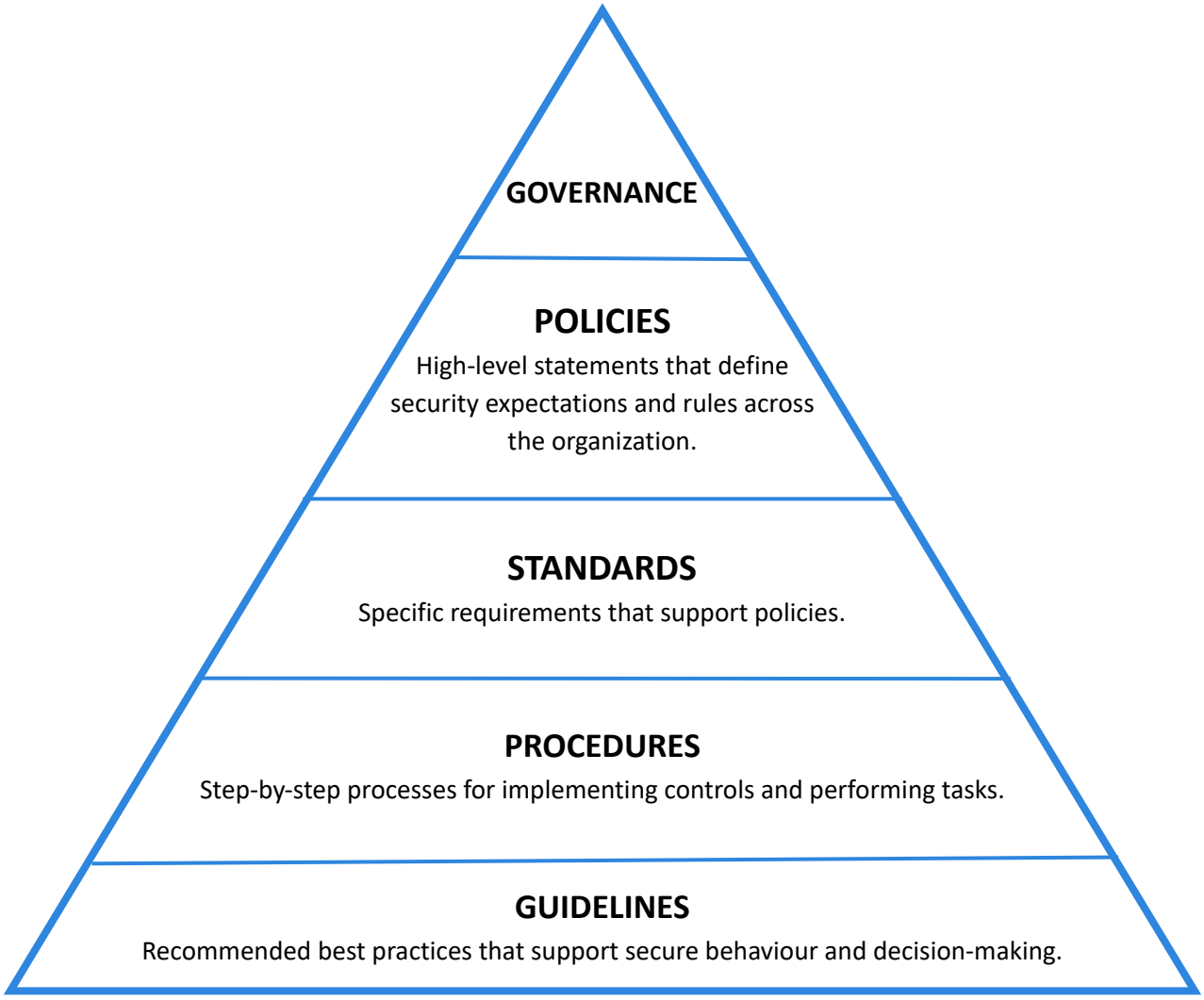
Security practices align with business operations, supporting productivity while reducing risk. The framework prioritizes practical, high-impact controls that address the organization's most critical risk areas

POLICY FRAMEWORK STRUCTURE

OVERVIEW

The policy framework defines how security requirements are structured and implemented across the organization. It establishes a hierarchy that supports consistency, clarity, and effective enforcement of security practices.

FRAMEWORK STRUCTURE



APPLICATION

This framework ensures that security controls are applied consistently and that all users understand their responsibilities for protecting systems and data.

POLICY GOVERNANCE MODEL

OVERVIEW

The policy governance model defines how policies are created, approved, maintained, and reviewed to ensure they remain relevant and effective.

POLICY LIFECYCLE

The policy lifecycle includes the following stages:

Development

Policies are developed based on identified risks, business requirements, and industry best practices.

Review

Policies are reviewed to ensure alignment with business operations, legal requirements, & other policies.

Approval

Policies are approved by management before implementation.

Implementation

Policies are communicated to all relevant users and enforced across systems and processes.

Maintenance

Policies are updated as needed to reflect changes in risk, technology, or business operations.

REVIEW CYCLE

- Policies will be reviewed at least annually.
- Updates will be made when significant changes occur.
- Policy compliance will be monitored periodically.

ACCOUNTABILITY

- Management is responsible for policy approval and oversight.
- Operations / IT is responsible for implementation and enforcement.
- Employees and contractors are responsible for compliance.

POLICY SUITE

INFORMATION SECURITY POLICY

PURPOSE

The purpose of this policy is to establish the foundation for information security at NorthPeak Growth Marketing by defining the principles and expectations for protecting company systems, data, and client information.

SCOPE

This policy applies to all employees, contractors, and third parties who access company systems, applications, or data.

POLICY STATEMENTS

NorthPeak Growth Marketing is committed to maintaining a secure environment through the following principles:

- Access to systems and data must be controlled based on business needs and job responsibilities.
- Sensitive data must be protected in accordance with its classification level.
- All users are responsible for safeguarding company systems and information.
- Security incidents must be reported and addressed in a timely manner.
- Third-party access must be controlled and monitored.
- Security controls must be implemented consistently across systems.

ROLES AND RESPONSIBILITIES

ROLE	RESPONSIBILITY
Management	Ensure security aligns with business objectives and risk tolerance
Operations / IT	Implement and maintain security controls
Employees	Follow security policies and protect company data
Contractors	Comply with access and security requirements

ENFORCEMENT

Failure to comply with this policy may result in disciplinary action, including revocation of system access or termination of employment or contract.

REVIEW AND MAINTENANCE

This policy will be reviewed annually or when significant changes occur to systems, risks, or business operations.

POLICY SUITE

ACCESS CONTROL POLICY

PURPOSE

The purpose of this policy is to define how access to systems, applications, and data is granted, managed, and revoked to reduce the risk of unauthorized access.

SCOPE

This policy applies to all users, systems, and applications used by NorthPeak Growth Marketing.

POLICY STATEMENTS

- Access must be granted based on job role and business requirements.
- Multi-factor authentication (MFA) must be enforced for all critical systems.
- Shared accounts and credentials are prohibited.
- Users must have only the minimum access required.
- Access must be reviewed periodically to ensure it remains appropriate.
- Access must be revoked immediately upon the termination of an employee or contractor.
- Privileged access must be restricted and monitored.

ROLES AND RESPONSIBILITIES

ROLE	RESPONSIBILITY
Management	Approve user access based on job role
Operations / IT	Provision and manage access controls
Employees	Use access responsibly and protect credentials

ENFORCEMENT

Unauthorized access or misuse of credentials may result in disciplinary action and removal of access privileges.

REVIEW AND MAINTENANCE

Access control processes and permissions will be reviewed periodically and updated as required.

POLICY SUITE

ACCEPTABLE USE POLICY

PURPOSE

The purpose of this policy is to define acceptable use of company systems, devices, and data.

SCOPE

This policy applies to all users of company systems, including employees and contractors.

POLICY STATEMENTS

- Company systems must be used for authorized business purposes only.
- Users must not share passwords or credentials.
- Unauthorized software or applications must not be installed.
- Users must not access malicious, illegal, or inappropriate content.
- Devices must be secured.
- Users must report suspicious activity or potential security incidents.

ROLES AND RESPONSIBILITIES

ROLE	RESPONSIBILITY
Management	Enforce appropriate system usage
Employees	Follow acceptable use requirements

ENFORCEMENT

Violations may result in disciplinary action, including suspension of access.

REVIEW AND MAINTENANCE

This policy will be reviewed annually.

POLICY SUITE

DATA CLASSIFICATION AND HANDLING POLICY

PURPOSE

The purpose of this policy is to define how data is classified, handled, and protected based on its sensitivity.

SCOPE

This policy applies to all company and client data handled by NorthPeak Growth Marketing.

POLICY STATEMENTS

- Data must be classified as Restricted, Confidential, Internal, or Public.
- Access to data must be based on classification and business need.
- Restricted data must receive the highest level of protection.
- Public sharing of sensitive data is prohibited.
- Data must be stored in approved systems.
- Data access and sharing must be controlled and monitored.

ROLES AND RESPONSIBILITIES

ROLE	RESPONSIBILITY
Operations / IT	Implement data protection controls
Employees	Handle data according to classification

ENFORCEMENT

Improper handling of data may result in disciplinary action.

REVIEW AND MAINTENANCE

Data classification practices will be reviewed periodically.

POLICY SUITE

INCIDENT RESPONSE POLICY

PURPOSE

The purpose of this policy is to define how security incidents are identified, reported, and managed.

SCOPE

This policy applies to all security incidents affecting systems, data, or operations.

POLICY STATEMENTS

- All security incidents must be reported immediately.
- Incidents must be documented and tracked.
- Appropriate containment and remediation actions must be taken.
- Communication must be controlled and coordinated.
- Lessons learned must be documented and used to improve security.

ROLES AND RESPONSIBILITIES

ROLE	RESPONSIBILITY
Management	Oversee incident response and decision-making
Operations / IT	Investigate and respond to incidents
Employees	Report incidents promptly

ENFORCEMENT

Failure to report incidents may result in disciplinary action.

REVIEW AND MAINTENANCE

Incident response procedures will be reviewed and updated regularly.

CONTROL AREAS MAPPING

OVERVIEW

This section maps the organization's security policies to key control areas to ensure cybersecurity risks are addressed in a structured and comprehensive manner.

The mapping aligns policy coverage with core security domains and supports a risk-based approach to implementing and managing controls.

CONTROL DOMAINS

The following control areas are the primary focus of the organization's security program. These domains reflect its most critical risk areas and align with widely recognized frameworks such as the NIST Cybersecurity Framework (CSF) and CIS Critical Security Controls.

GOVERNANCE & OVERSIGHT	IDENTITY & ACCESS MANAGEMENT	USER BEHAVIOUR & ACCEPTABLE USE	DATA PROTECTION	INCIDENT DETECTION & RESPONSE
Information Security Policy	Access Control Policy	Acceptable Use Policy	Data Classification Policy	Incident Response Policy
Defines security principles, establishes accountability, and ensures alignment with business objectives	Enforces MFA, role-based access control (RBAC), least privilege, and access lifecycle management	Defines acceptable system usage, prohibits credential sharing, and enforces secure behaviour	Defines data classification levels, restricts access, and enforces secure data handling practices	Defines incident reporting, response procedures, and continuous improvement practices

CONTROL AREAS MAPPING

CONTROL COVERAGE SUMMARY

The policy suite provides coverage across all critical control areas required to manage the organization's primary cybersecurity risks.

- Identity & Access Management is the highest-priority area due to risks from phishing, credential theft, and unauthorized access.
- Data Protection ensures that sensitive client and financial data is properly secured.
- User Behavior reduces risk through defined acceptable use and security awareness.
- Incident Response ensures the organization can respond effectively to security events.
- Governance provides oversight and ensures consistency across all controls.

FRAMEWORK ALIGNMENT

The control areas align with key functions of the NIST Cybersecurity Framework:

NIST CSF FUNCTION	CONTROL AREA
GOVERN	Governance & Oversight
IDENTIFY	Risk Management (covered in governance and policies)
PROTECT	Identity & Access Management, Data Protection, Acceptable Use
DETECT	Incident Detection (part of Incident Response)
RESPOND	Incident Response
RECOVER	Continuous Improvement (covered in governance and policy lifecycle)

KEY INSIGHT

The mapping demonstrates that the organization's policy framework provides structured coverage of critical security domains. The strongest emphasis is placed on identity and access controls, reflecting the organization's primary risk exposure.

RISK ALIGNMENT

OVERVIEW

This section demonstrates how the organization's policy framework directly addresses the key cybersecurity risks identified during the security assessment.

By aligning policies to specific risks, the organization ensures that security controls are practical, targeted, and focused on reducing real-world exposure.

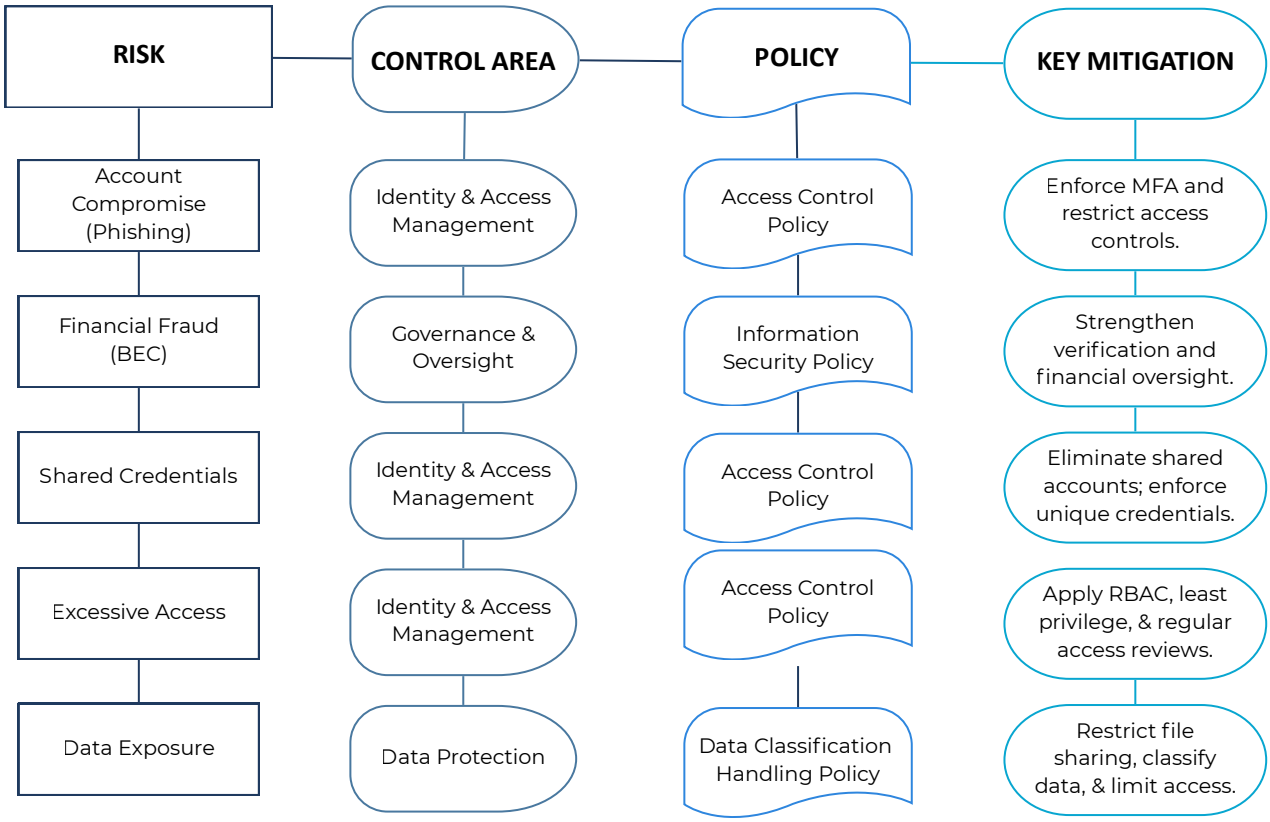
KEY RISK AREAS

The following high-priority risks were identified:

- Account compromise through phishing
- Financial fraud (Business Email Compromise)
- Shared and unsecured credentials
- Excessive and unmanaged access
- Data exposure through improper file sharing

These risks primarily affect identity management, access control, and data protection.

RISK-TO-CONTROL MAPPING



RISK ALIGNMENT

RISK REDUCTION STRATEGY

The organization's approach focuses on addressing high-impact risks through foundational controls:

Identity Protection

Strengthening authentication and access management to prevent unauthorized access

Credential Security

Eliminating shared credentials and enforcing secure authentication practices

Access Governance

Ensuring users only have the access required for their roles

Data Protection

Controlling how sensitive data is accessed, shared, and stored

PRIORITY FOCUS AREAS

Based on the assessment, the following areas provide the greatest risk reduction:

- Enforcement of multi-factor authentication (MFA)
- Implementation of role-based access control (RBAC)
- Removal of shared credentials
- Restriction of public data sharing
- Introduction of financial verification controls

KEY INSIGHT

The majority of identified risks are not caused by advanced threats but by gaps in foundational security controls. By implementing targeted policies and controls in identity, access, and data protection, the organization can significantly reduce its overall risk exposure.

CONTINUOUS IMPROVEMENT

OVERVIEW

Cybersecurity governance is an ongoing process that requires continuous evaluation and improvement. The organization will maintain and enhance its security posture by regularly monitoring, reviewing, and refining policies and controls.

CONTINUOUS IMPROVEMENT ACTIVITIES

The organization will implement the following practices:

- Conduct periodic risk assessments to identify emerging threats.
- Review and update policies regularly to reflect changes in business operations and technology.
- Monitor the effectiveness of security controls.
- Perform access reviews and audits.
- Incorporate lessons learned from security incidents.

METRICS AND MONITORING

The effectiveness of the framework will be measured through:

- MFA adoption across systems
- Reduction in shared credential usage
- Completion of access reviews
- Number and resolution time of security incidents

REVIEW CYCLE

- Policies will be reviewed at least annually.
- Controls will be evaluated periodically.
- Updates will be made based on risk, incidents, or operational changes.

KEY INSIGHT

Continuous improvement ensures that the organization's security framework remains effective, adaptable, and aligned with evolving risks and business needs.

APPENDIX

DEFINITIONS

TERM	DEFINITION
Asset	Any system, data, or resource of value to the organization
Risk	The potential for loss or damage when a threat exploits a vulnerability
Control	A measure implemented to reduce risk
MFA (Multi-Factor Authentication)	An authentication method requiring multiple forms of verification
RBAC (Role-Based Access Control)	Access control based on user roles and responsibilities

ACRONYMS

ACRONYM	MEANING
GRC	Governance, Risk, and Compliance
MFA	Multi-Factor Authentication
RBAC	Role-Based Access Control
NIST	National Institute of Standards and Technology
CIS	Center for Internet Security

POLICY SUMMARY

POLICY	PURPOSE
Information Security Policy	Defines overall security principles and governance
Access Control Policy	Manages access to systems and data
Acceptable Use Policy	Defines appropriate system usage
Data Classification Policy	Protects sensitive data
Incident Response Policy	Manages security incidents

DOCUMENT INFORMATION

- Document Title: Cybersecurity Governance & Policy Framework
- Organization: NorthPeak Growth Marketing
- Version: 1.0
- Date: March 2026